

Introduction to

Information Assurance and Security

College of Computer Studies

University of Perpetual Help System DALTA

Foundations of Information Security

The CIA Triad and Security Principles

What is information security?

The practice of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

ISO/IEC 27001 says it more compactly: the preservation of confidentiality, integrity, and availability of information.

Three ideas worth holding onto



A process, not a product

No tool makes a system secure permanently. A firewall bought last year is only as good as its last review.



Always a trade-off

Every control costs money, speed, or convenience. Someone has to decide what is worth paying.



Managed, not eliminated

There is no zero-risk system. The goal is bringing risk down to a level the organization can accept.

What are we protecting?

Four categories of asset, and they are not equally replaceable



Data

The information itself, wherever it happens to live.

EXAMPLES

- Student and patient records
- Financial transactions
- Research and design files



Systems

The machines and services that store and move that data.

EXAMPLES

- Servers and endpoints
- Network devices
- Cloud services and APIs



People

Identities, credentials, and the trust attached to them.

EXAMPLES

- Passwords and MFA tokens
- Access rights and roles
- Staff judgment under pressure



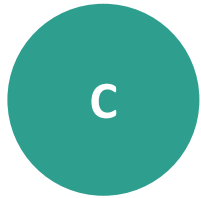
Reputation

What an organization loses first and recovers last.

EXAMPLES

- Customer and student trust
- Regulatory standing
- Partner contracts

Data can be restored from backup. Reputation cannot. That is why a breach is a security problem and a business problem at the same time.



Confidentiality

Only the people who are supposed to see the information can see it.

TYPICAL CONTROLS

- **Encryption** Scrambles data so it is unreadable without the key, at rest and in transit
- **Access control** Permissions and roles that limit who can open what
- **Classification** Labelling data so people know how carefully to handle it
- **Need-to-know** Access granted for a job to be done, not for a rank held

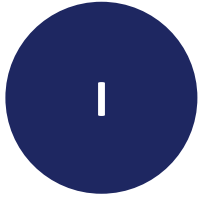
WHEN IT BREAKS

A clinic emails its patient list to the wrong distribution group.

Nothing was altered. Nothing went offline. The information simply reached people with no right to it.

WORTH REMEMBERING

Confidentiality is about authorization, not secrecy. Data can be widely shared and still be confidential, as long as everyone holding it is supposed to have it.



Integrity

The information is accurate, complete, and has not been altered without authorization.

TYPICAL CONTROLS

- **Hashing**
Produces a fingerprint that changes if even one character changes
- **Digital signatures**
Prove who wrote something, and that it was not edited since
- **Version control**
Keeps a history so you can see what changed and when
- **Audit logs**
Record who did what, which makes tampering detectable

WHEN IT BREAKS

A payroll file is edited to change one bank account number.

The file still opens. It still looks normal. The error surfaces only after the money has moved.

WORTH REMEMBERING

Integrity failures are the quietest of the three. Confidentiality and availability failures announce themselves, but altered data can sit undetected for months.



Availability

The information and the systems holding it are there when someone legitimately needs them.

TYPICAL CONTROLS

- **Redundancy**
A second server, link, or power source ready to take over
- **Backups**
Copies that let you rebuild after loss, tested by actually restoring
- **DDoS protection**
Absorbs or filters floods of traffic aimed at knocking you offline
- **Capacity planning**
Enough headroom that a normal peak does not look like an attack

WHEN IT BREAKS

Enrollment opens and the student portal collapses under the load.

No attacker. No stolen data. The service is simply useless at the one moment it mattered.

WORTH REMEMBERING

Availability is the leg most often broken by accident rather than by an attacker. Storms, power cuts, and bad capacity estimates cause more downtime than adversaries do.

The three goals pull against each other

Strengthening one leg often weakens another - this is the heart of security design



Stronger confidentiality

Full-disk encryption plus multi-factor authentication

COSTS YOU

Slower logins, and a lost key can mean permanently lost data

Availability suffers



Stronger integrity

Every change needs approval and is logged

COSTS YOU

Work slows down and staff route around the process

Availability suffers



Stronger availability

Data replicated across many servers and backups

COSTS YOU

More copies means more places an attacker can steal from

Confidentiality suffers

ISO/IEC 27001: the triad turned into a system

What it is

An international standard for building and running an Information Security Management System, or ISMS.

It does not tell you which firewall to buy. It tells you how to decide, document, and keep improving.

1

Risk-based, not checklist-based

Controls are chosen because a risk assessment justified them.

2

Plan-Do-Check-Act

The ISMS is reviewed and improved on a cycle. It is never finished.

3

Annex A control catalogue

93 reference controls across four themes, listed in Annex A.

4

Independently certifiable

An accredited body audits you. Clients ask to see the certificate.

KNOWLEDGE CHECK

Question 1 of 4

A storm knocks out power and staff cannot reach patient records for six hours.
Which leg of the triad is affected?

A

Confidentiality

B

Integrity

C

Availability

D

None of these

KNOWLEDGE CHECK

Question 2 of 4

Which control most directly protects integrity?

A

Encryption

B

Hashing

C

Redundancy

D

Firewalls

KNOWLEDGE CHECK

Question 3 of 4

ISO/IEC 27001 certifies an organization's...

A

Firewall brand

B

Management system

C

Staff skills

D

Source code

KNOWLEDGE CHECK

Question 4 of 4

"Security is a process, not a product" means...

A

Tools are useless

B

Controls need review

C

Only policy matters

D

Security is free

Graded Seatwork: CIA Triad Scenario Analysis

1

A short written paper covering the four scenarios on the slides that follow.

2

For every scenario, name the CIA principle violated.

3

Justify your choice in two to three sentences.

4

Where more than one principle is affected, say which is primary and why.

5

Suggest one control that would have prevented or reduced the impact.

Scenario 1 of 4

Analyze this in writing. This is part of your graded seatwork.

A hospital clerk browses the medical records of a celebrity patient out of curiosity.

1

Principle

Name which leg of the triad was violated.

2

Justification

Two to three sentences tied to this scenario.

3

Primary

If more than one applies, say which comes first.

4

Control

One measure that would have prevented or reduced it.

Scenario 2 of 4

Analyze this in writing. This is part of your graded seatwork.

A student alters a grade in the registrar database after gaining admin access.

1

Principle

Name which leg of the triad was violated.

2

Justification

Two to three sentences tied to this scenario.

3

Primary

If more than one applies, say which comes first.

4

Control

One measure that would have prevented or reduced it.

Scenario 3 of 4

Analyze this in writing. This is part of your graded seatwork.

Ransomware encrypts a file server and staff cannot open anything.

1

Principle

Name which leg of the triad was violated.

2

Justification

Two to three sentences tied to this scenario.

3

Primary

If more than one applies, say which comes first.

4

Control

One measure that would have prevented or reduced it.

Scenario 4 of 4

Analyze this in writing. This is part of your graded seatwork.

A misconfigured cloud bucket exposes ten years of student records to the open internet.

1

Principle

Name which leg of the triad was violated.

2

Justification

Two to three sentences tied to this scenario.

3

Primary

If more than one applies, say which comes first.

4

Control

One measure that would have prevented or reduced it.

Threat Landscape and Attack Vectors

Threats, Vulnerabilities, and Attacks

Threat, vulnerability, risk

Three words students most often use interchangeably - and should not

THREAT

Anything with the potential to cause harm.

A flood, a criminal group, a careless employee.

VULNERABILITY

A weakness that a threat could exploit.

An unpatched server, a weak password policy.

ASSET

The thing of value you are protecting.

A database, a service, a reputation.

RISK

Risk = Threat x Vulnerability x Impact on the asset

Remove any one factor and the risk collapses. That is why patching works, and why an unexploitable weakness is not an emergency.

Clause 6.1, part one: finding and sizing the risk

The first half of the process is description. Nothing gets fixed yet.

1

Identify

List the assets worth protecting, the threats to them, and the vulnerabilities those threats could exploit.

PRODUCES

A risk register

IN PRACTICE

Usually a spreadsheet. One row per risk, written in the vocabulary from the previous slide.

2

Analyse

Estimate how likely each risk is, and how much damage it would do if it actually happened.

PRODUCES

A comparable risk level

IN PRACTICE

Likelihood times impact, often on a simple 1 to 5 scale, so unlike risks can be ranked beside each other.

Both steps are description, not decision. You are building the picture that the decisions will rest on.

Clause 6.1, part two: deciding what to do

The second half is judgment, and it has to be documented

3

Evaluate

Compare each risk against the acceptance criteria the organization agreed on in advance.

PRODUCES

A ranked list and a tolerance line

IN PRACTICE

The line has to be set before you look at results, or every decision turns into an argument after the fact.

4

Treat

Choose a response for everything sitting above that line, and record why you chose it.

PRODUCES

A Statement of Applicability

IN PRACTICE

Names each control, says whether it applies, and justifies the call. This is what an auditor reads first.

Repeatable is the word that matters. The same inputs should produce the same rating no matter who runs the assessment.

Treating a risk by changing the risk itself

Two of the four options act on the risk. One shrinks it, the other removes it.



Mitigate

Apply a control that lowers the likelihood, the impact, or both.

EXAMPLE

Patch the server, enable MFA, encrypt the database, train the staff.

WATCH OUT

The default answer, and usually the most expensive. Ask what the control costs before reaching for it.



Avoid

Stop doing the risky activity, so the risk cannot arise at all.

EXAMPLE

Retire the legacy system rather than patching it indefinitely.

WATCH OUT

Cleanest option on paper, rarely available in practice, because the risky activity is usually the business.

Neither option is free. Mitigation costs money and friction. Avoidance costs you the activity itself.

Treating a risk by changing who carries it

The risk stays roughly the same size. What changes is who is left holding it.



Transfer

Shift the financial loss to another party, usually by contract.

EXAMPLE

Cyber insurance, or outsourcing the service to a provider.

WATCH OUT

The money moves. The responsibility, the regulator, and the reputation do not move with it.



Accept

Decide the risk is tolerable, and put that decision in writing.

EXAMPLE

Signed off by someone with authority to carry the consequence.

WATCH OUT

Legitimate only when documented. An undocumented acceptance is neglect with better manners.

Accepting a risk is a decision, not a shrug. Ask who signs - it should be whoever carries the consequence, which is rarely the IT team.

The attackers everyone pictures

Deliberate, organized, and properly resourced



Organized cybercrime

MOTIVE

Money

Ransomware crews and fraud operations that run like businesses, with affiliates, support desks, and revenue targets.

WHAT THIS MEANS FOR YOU

They choose targets on expected payout, not on principle. A school with weak backups is a good target.



Nation-state actors

MOTIVE

Intelligence and disruption

Well funded and patient. Willing to sit hidden inside a network for months before doing anything visible.

WHAT THIS MEANS FOR YOU

Rarely your problem directly, but their tools leak, and reach criminal hands within months.

Both groups are professional. Neither is improvising, and neither is deterred by a firewall alone.

The attackers that are easier to overlook

Less dramatic, and behind a large share of actual incidents



Insiders

MOTIVE

Grievance, gain, or plain carelessness

Already trusted and already inside. Most insider incidents are mistakes rather than malice, which makes them easy to miss and easier to excuse.

WHAT THIS MEANS FOR YOU

Access reviews and audit logs matter far more here than any perimeter control.



Opportunists

MOTIVE

Attention, or simple convenience

Often unskilled, running automated tools that scan the whole internet looking for anything left open or unpatched.

WHAT THIS MEANS FOR YOU

You do not need to be interesting. You only need to be reachable.

The opportunist is the reason "we are too small to be a target" stopped being true.

Attacks that target the technology

Each of these exploits a flaw in a system rather than a person



Malware

Malicious code that runs on the victim system.

EXAMPLES

- Ransomware
- Trojans and worms
- Spyware and keyloggers

BREAKS

Availability first, often confidentiality too



Injection attacks

Untrusted input is executed as if it were code.

EXAMPLES

- SQL injection
- Command injection
- Cross-site scripting

BREAKS

Confidentiality and integrity



Denial of Service

Exhausts bandwidth, connections, or compute until real users are locked out.

EXAMPLES

- DoS from one source
- DDoS from a botnet
- Application-layer floods

BREAKS

Availability, by definition

Patching, input validation, and capacity planning are the defenses here. All three are technical.

Attacks that target people and connections

None of these needs a software flaw, which is why patching alone will not stop them



Social engineering

Attacks the person rather than the machine.

EXAMPLES

- Phishing and spear phishing
- Vishing, by phone
- Pretexting and impersonation

BREAKS

Whatever the tricked person could reach



Credential attacks

Takes over a legitimate account instead of breaking in.

EXAMPLES

- Brute force and dictionary
- Credential stuffing
- Password reuse across sites

BREAKS

Confidentiality first, then anything else



Man-in-the-middle

Intercepts traffic between two parties on an untrusted network.

EXAMPLES

- Rogue public Wi-Fi
- Session hijacking
- Downgrade attacks

BREAKS

Confidentiality, and integrity if traffic is altered

These succeed against fully patched systems. Awareness training and MFA are controls, not formalities.

Ways in that face the internet

Routes an attacker can reach from anywhere, without ever touching your building

1

Email

Still the single most common entry point. One click, one attachment.

HOW IT LOOKS

A convincing invoice, a shared document link, or a message from a name you recognize.

FIRST DEFENSE

Filtering, plus staff who feel safe reporting a mistake quickly rather than hiding it.

2

Exposed services

Anything internet-facing with open ports, default credentials, or missing patches.

HOW IT LOOKS

An admin panel reachable from the public internet, still using last year's password.

FIRST DEFENSE

An asset inventory and a patching routine. You cannot protect a server you forgot you had.

3

Web applications

Input fields that accept rather more than they should.

HOW IT LOOKS

A search box or login form that passes user text straight into a database query.

FIRST DEFENSE

Input validation and testing before release, not after an incident.

All three are scanned automatically, around the clock, whether or not anyone is targeting you specifically.

Ways in that bypass the perimeter

Routes that arrive through something already trusted, rather than through the network edge

4

Removable media

USB drives and external disks, carried in by hand.

HOW IT LOOKS

A found drive plugged in out of curiosity, or a contractor arriving with their own disk.

FIRST DEFENSE

Port policy and endpoint controls. No firewall ever sees this traffic.

5

Supply chain

A trusted vendor, library, or update channel that has itself been compromised.

HOW IT LOOKS

A routine software update that arrives signed and legitimate, and is neither.

FIRST DEFENSE

Vendor review, and actually knowing what your systems depend on.

6

People

A convincing phone call to the help desk beats most firewalls.

HOW IT LOOKS

An urgent request from "IT" to confirm a password before some deadline passes.

FIRST DEFENSE

Verification procedures that do not bend for urgency or for seniority.

Every route here enters through something already trusted, which is exactly why perimeter controls never see it coming.

KNOWLEDGE CHECK

Question 1 of 4

An internet-facing server missing three months of patches is an example of a...

A

Threat

B

Vulnerability

C

Risk

D

Asset

KNOWLEDGE CHECK

Question 2 of 4

A finance clerk is tricked by a convincing email into wiring funds. Which attack family?

A

Malware

B

Social engineering

C

Denial of Service

D

Injection

KNOWLEDGE CHECK

Question 3 of 4

Which of these is a risk treatment rather than a control?

A

Patch the server

B

Accept and sign off

C

Install antivirus

D

Require MFA

KNOWLEDGE CHECK

Question 4 of 4

An attacker floods a school portal so students cannot enroll. Which leg breaks first?

A

Confidentiality

B

Integrity

C

Availability

D

None of these

ACTIVITY

Think-Pair-Share

Find the vulnerabilities in the applications you already use every day



THINK

On your own, pick one app you opened today. List three ways it could be attacked or misused.



PAIR

Compare lists with a partner. For each item decide together: is this a threat, a vulnerability, or a risk?



SHARE

Each pair reports one finding to the class, naming the attack family it belongs to.

Use the exact vocabulary from this week when you report back. Close is not the same as correct.

Six things to carry forward

1

Every control you meet this semester protects confidentiality, integrity, or availability. Ask which one.

2

Strengthening one leg of the triad usually costs you another. Security is chosen trade-offs, not maximums.

3

A threat is a possible cause of harm. A vulnerability is the weakness it uses. Risk is what the two could cost.

4

ISO 27001 builds an auditable management system on that same triad, and requires a documented risk process.

5

Attacks are automated and sold as a service, so being small or uninteresting is no longer a defense.

6

Most breaches start with a person, not a machine. Awareness is a control, not a formality.

Next session - Week 3: Security Policies, Standards, and Practices, including ISO 27001 and NIST CSF in full